America's Cyber Defense Agency

NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

Advisory Number: AA-2024-001

Date: August 30, 2024

Title: Increase in Phishing Campaigns by APTs Utilizing Malicious Macros in Word Documents

Overview:

The Cybersecurity and Infrastructure Security Agency (CISA) has observed a significant uptick in phishing campaigns conducted by Advanced Persistent Threat (APT) groups. These campaigns are primarily targeting organizations in various sectors, including defense, critical infrastructure, and private industry. The adversaries are utilizing Word documents containing malicious macros to compromise systems.

Technical Details:

CISA has identified that these phishing campaigns leverage social engineering techniques to deceive recipients into opening malicious Word attachments. The Word documents contain macros that, when enabled, execute a series of actions designed to download and install malware on

the victim's system. The malware variants observed in these campaigns are capable of data exfiltration, remote access, and lateral movement within networks.

Key characteristics of the observed phishing campaigns include:

- **Email Subjects:** Often related to urgent requests, invoices, or official documents.
- **Attachment Names:** Typically use filenames that appear legitimate and relevant to the recipient (e.g., "Invoice_12345.docx" or "Project_Update.docx").
- **Macros:** Embedded within the Word documents, these macros are obfuscated to evade detection by standard antivirus solutions.
- **Malware Payload:** Once the macro is enabled, it connects to a remote server to download additional payloads. Common payloads include RATs (Remote Access Trojans) and data-stealing malware.

Indicators of Compromise (IOCs):

CISA has compiled a list of IOCs associated with these campaigns. Organizations are advised to monitor for the following indicators:

Email-Based IOCs:

- Subjects: "Urgent Invoice," "Payment Confirmation," "Official Document," "Project Update"
- Attachment Names: "Invoice_12345.docx," "Payment_Details.docx," "Contract_Agreement.docx"

Network-Based IOCs:

- IP Addresses: 3.33.139.32, 183.111.182.214

File-Based IOCs:

- File Hashes (MD5/SHA-256): fa146ba5e904ce92a9a87d2d1c551da9abe6116a04f3da0b9ab12b9563c78721
- Filenames: As mentioned above

Mitigation Recommendations:

CISA recommends the following measures to mitigate the risk associated with these phishing campaigns:

1. **User Awareness Training:** Educate users on the risks of enabling macros in unsolicited documents and how to identify phishing attempts.
2. **Email Filtering:** Implement advanced email filtering solutions to detect and block phishing emails.
3. **Endpoint Protection:** Ensure that endpoint protection solutions are configured to detect and block macro-based malware.
4. **Network Segmentation:** Segment critical networks to limit the lateral movement of potential malware.
5. **Incident Response:** Develop and maintain an incident response plan to address potential compromises promptly.

Reporting:

Organizations that identify any activity related to these phishing campaigns should report the details to CISA immediately. Sharing information about attempted or successful attacks can help mitigate the risk for other organizations.

For further information and updates on this advisory, visit the CISA website or contact the CISA Cybersecurity Division.

Contact Information:

- **Website:** www.cisa.gov
- **Email:** kbumang1@jh.edu

End of Advisory